

DUCKWORKS

AI Risk Classification & Assessment Methodology

Draft for Approval - No System Scoring Authorized

Document Control	Value
Document ID	DW-WING-RISK-01
Version	0.9
Status	Draft for Approval
Method owner	Risk & Compliance
Proposed approver	Chief Risk & Compliance Officer / AI Governance Committee
Effective date	Not effective until formal approval
Assessment scope	Seven baseline inventory entries: six managed AI systems plus AI-007 shadow-AI discovery condition
Classification	Portfolio / Synthetic / Non-production

Approval gate. The approved inventory explicitly keeps Inherent Risk, Control Effectiveness and Residual Risk as “Not Assessed” until a formal methodology is approved. This draft therefore defines the method only and does not score any Duckworks system.

1. Executive summary

This methodology defines a scenario-based, evidence-aware process for assessing AI risk at Duckworks. It is designed to support proportional governance across the approved baseline inventory without turning uncertain AI risk into a misleadingly precise number.

- Assess concrete cause -> event -> impact scenarios, not generic labels such as “bias risk” or “security risk”.
- Assess inherent risk before crediting Duckworks-specific mitigating controls.
- Evaluate control design, operating effectiveness and evidence confidence separately; planned controls receive no residual-risk credit.
- Reassess impact and likelihood after operating controls to determine current residual risk; do not mathematically “discount” inherent risk by a control percentage.
- Use the highest material scenario to drive the system-level governance rating; do not average severe safety, rights or confidentiality risks away.
- Keep legal/regulatory classification separate from internal enterprise risk. A prohibited or otherwise unlawful use cannot be approved through risk acceptance.

Key methodological position. The 1-5 values are ordinal matrix coordinates. They help structure judgment; they are not measurements with equal intervals. The risk band and narrative rationale are authoritative, not the arithmetic product of the numbers.

2. Basis, scope and boundaries

The method is tailored to the approved QuackTrack inventory, which contains seven baseline entries and records their intended purpose, lifecycle, users, affected persons, data, automation/human oversight, third-party involvement, governance status, controls and monitoring fields. Formal risk fields remain “Not Assessed” pending methodology approval.

Inventory entry	Current lifecycle	Assessment note
AI-001 DuckDesign AI	Pilot	Engineering/product context; no score in this methodology.
AI-002 QuackBot	Development	Customer-facing GenAI/RAG context; no score.
AI-003 FeatherForecast	Production	Operational forecasting context; no score.
AI-004 WingInspect Vision	Pilot	Manufacturing quality context; no score.
AI-005 DuckTalent AI	Concept	Recruitment/affected-person context; no score.
AI-006 PondGPT	Pilot	Enterprise GenAI/RAG context; no score.
AI-007 Unregistered GenAI Usage	Discovered	Organizational discovery condition; material discovered uses must be decomposed into separate records before formal scoring.

2.1 Legal and framework separation

Duckworks internal risk ratings are enterprise governance decisions. They are not legal classifications. Regulatory triage is a separate gate performed using applicable law and specialist review. Voluntary standards and frameworks can inform governance practice but do not independently establish legal compliance or certification.

Classification	How this methodology treats it
Mandatory legal requirement	Separate applicability/triage gate. If a practice is prohibited or otherwise unlawful, it cannot be approved by lowering or accepting an internal risk score.
Standards/framework guidance	Used as design input for governance, risk, control and

Classification	How this methodology treats it
	evidence practices; not treated as law.
Duckworks organizational practice	The scales, matrix, approval authorities, escalation rules and evidence expectations in this document.
Project assumption	Any unverified fact that materially affects purpose, affected persons, safety, data, autonomy, provider or jurisdiction must be documented and may trigger reassessment.

3. Assessment workflow

Stage	Required activity	Output / gate
1. Inventory & scope	Confirm intended purpose, owner, lifecycle, users, affected persons, data, provider/model, integrations, geography and decision role.	Validated assessment context. Incomplete material fields block scoring.
2. Regulatory triage	Screen legal role, prohibited/unlawful use, high-impact classifications, transparency/privacy/product/employment/cyber obligations as applicable.	Legal classification/flag kept separate from enterprise rating.
3. Scenario identification	Write material cause -> event -> impact scenarios across relevant domains.	Scenario register.
4. Inherent risk	Assess impact and likelihood without credit for specific Duckworks mitigating controls.	Inherent matrix coordinate and band.
5. Control assessment	Assess control design, operating effectiveness and evidence confidence.	Control effectiveness conclusion; planned controls not credited.
6. Residual risk	Reassess impact and likelihood after implemented controls.	Current residual matrix coordinate and band.
7. Treatment / target	Avoid, reduce, transfer/share selected exposure, accept within authority, suspend or retire.	Treatment plan and target risk (planning state only).
8. Approval / monitoring	Apply acceptance authority, escalation thresholds, monitoring and reassessment triggers.	Decision record, evidence pointers and review cadence.

4. Risk scenario domains

Domains are prompts for scenario discovery, not weights to be averaged. A single scenario may span multiple domains.

Domain	Assessment lens
Fundamental rights, fairness & discrimination	Unequal treatment, exclusion, accessibility, discrimination, contestability and adverse impacts on people.
Safety & physical harm	Injury, unsafe product outcomes, hazardous decisions, quality escapes and loss of safe fallback.
Privacy, confidentiality & data governance	Personal data, confidential/IP data, minimization, provenance, retention, access boundaries and leakage.
Security, abuse & adversarial manipulation	Prompt injection, poisoning, model abuse, exfiltration, insecure tools/integrations, excessive permissions and supply-chain threats.
Reliability, robustness & performance	Hallucination, accuracy, false positives/negatives, drift, distribution shift, brittleness and unstable behavior.
Transparency & explainability	Disclosure, traceability, understandable rationale/limitations and ability to challenge outputs.
Human oversight & automation bias	Over-reliance, ineffective review, unclear authority, inadequate competence and inappropriate autonomy.
Third-party & supply chain	Provider dependency, contractual terms, subprocessors, model/service changes, resilience and exit.
Operational, financial & reputational	Disruption, bad planning, cost, service quality, complaints, stakeholder trust and recovery burden.
Legal, regulatory & compliance	Potential breach of applicable duties, required approvals, recordkeeping and governance conditions. Legal stop-gates remain separate.

5. Impact scale

Impact is the highest credible consequence for the scenario across relevant impact dimensions. Do not average dimensions. Evaluate credible scope, affected population, reversibility, duration and severity. Where uncertainty could materially change the rating, record the uncertainty and seek evidence rather than selecting a midpoint for convenience.

Level	Anchor	Typical decision cues
1 - Negligible	Minimal, readily reversible effect; no material rights, safety, privacy, security or business impact.	Minor rework or inconvenience; no sensitive data; no consequential decision.
2 - Minor	Limited/localized effect; straightforward remediation; low sensitivity and small affected scope.	Small process delay; isolated low-impact output error; contained internal issue.
3 - Moderate	Meaningful impact on individuals or operations; recoverable with management action.	Material planning error; limited confidentiality incident; repeated customer inconvenience; localized unfair outcome.
4 - Major	Significant rights, privacy, security, product-quality, financial, operational or reputational impact requiring substantial remediation.	Sensitive-data exposure; serious process discrimination; material defect escape; repeated harmful advice; major outage or supplier disruption.
5 - Severe	Potential serious physical harm, systemic fundamental-rights harm, major restricted-data/IP breach, or broad/long-lasting/irreversible impact.	Unsafe product outcome; systemic employment discrimination; major confidential design leakage; widespread loss of control over consequential decisions.

Impact override. Any residual scenario rated Impact 5 receives mandatory AI Governance Committee escalation regardless of the matrix band. Potential unlawfulness, serious safety exposure or systemic rights harm also triggers specialist escalation outside the matrix.

6. Likelihood scale

Likelihood is an ordinal judgment for the defined assessment horizon. The assessor records the horizon and basis. Consider exposure frequency, user behavior, attackability, historical events/near misses, model failure evidence, data quality, change velocity, third-party uncertainty and dependence on human review. Inherent likelihood removes credit for Duckworks-specific mitigations but retains the system's intended purpose and fundamental architecture.

Level	Anchor	Evidence cues
1 - Rare	Requires an exceptional combination of conditions; occurrence is credible but not expected in the assessment horizon.	Very limited exposure or intrinsic barriers; no meaningful recurrence evidence.
2 - Unlikely	Credible but uncommon in normal or reasonably foreseeable use.	Limited exposure; difficult-to-trigger failure; weak history of occurrence.
3 - Possible	Foreseeable under ordinary or reasonably foreseeable use.	Known failure mode can occur under realistic conditions; mixed evidence.
4 - Likely	Expected to occur repeatedly without effective controls.	Frequent exposure, attractive attack path, unstable behavior or recurring error pattern.
5 - Almost Certain	Persistent, observed, or structurally expected absent redesign or effective control.	Condition already occurring, inherent recurring exposure, or failure mechanism is routinely encountered.

7. 5x5 risk matrix and rating logic

Use the impact and likelihood values as matrix coordinates. The matrix band is the governance rating. An optional product (I x L) may be stored only as a sorting aid; it is not the authoritative risk measure and must not be used to override the band, impact override or legal gate.

Impact \ Likelihood	1 Rare	2 Unlikely	3 Possible	4 Likely	5 Almost Certain
1 Negligible	Low	Low	Low	Low	Moderate
2 Minor	Low	Low	Moderate	Moderate	High
3 Moderate	Low	Moderate	Moderate	High	High
4 Major	Moderate	Moderate	High	High	Critical
5 Severe	Moderate	High	High	Critical	Critical

Rating	Governance meaning
Low	Within routine delegated risk appetite if no legal/specialist stop condition exists.
Moderate	Requires documented controls, monitoring and second-line visibility; owner acceptance within delegated authority only.
High	Outside system-owner self-acceptance. AI Governance Committee approval/treatment and enhanced evidence required before material production use.
Critical	Outside normal risk appetite. New production deployment is blocked pending reduction or exceptional executive acceptance; immediate escalation required.

8. Inherent risk

Inherent risk is the risk of a defined scenario before crediting specific Duckworks mitigating controls. It is not a fiction in which the system has no architecture, users or intended purpose. The assessor keeps the actual deployment context but removes reliance on controls such as human review, DLP, security filters, testing, approval gates, contractual safeguards or monitoring when determining the inherent rating.

1. Confirm the scenario and credible impact chain.
2. Rate inherent impact using the highest credible consequence.
3. Rate inherent likelihood for the stated horizon without Duckworks-specific mitigation credit.
4. Map the I/L coordinate to the risk band.
5. Record rationale, assumptions, evidence and confidence; do not substitute the number for the explanation.

System-level roll-up. The system-level inherent rating is the highest material scenario band, subject to expert judgment and escalation overrides. Averages, medians and weighted means must not be used to dilute a severe scenario.

9. Control effectiveness

Control effectiveness is not a percentage discount. Duckworks evaluates whether key controls are appropriately designed, implemented, operating, and evidenced. For a control set, the overall conclusion is constrained by material control gaps and critical dependencies.

Rating	Meaning	Minimum evidence expectation
Not Implemented / Ineffective	No meaningful operating control, or control fails its objective.	No reliable evidence or evidence demonstrates failure.
Weak	Ad hoc, incomplete or inconsistently applied; material gaps remain.	Limited evidence; key coverage gaps or exceptions unresolved.
Partially Effective	Control operates but coverage, consistency, testing or dependency management is incomplete.	Some current evidence; gaps tracked with owners/dates.
Effective	Implemented, appropriately designed and operating with supporting evidence.	Repeatable current evidence linked to the control objective.
Strong / Verified	Effective control with mature monitoring and independent or second-line verification.	High-quality current evidence; testing/assurance supports sustained operation.

9.1 Control assessment dimensions

Dimension	Question
Design adequacy	If the control operates as designed, would it materially address the scenario cause, event, consequence or detection/recovery need?
Implementation	Is the control actually deployed in the relevant environment, population, workflow and model/version?
Operating effectiveness	Does evidence show the control performs consistently over the required period or triggering events?
Coverage & dependency	Does the control cover the relevant users, data, integrations, vendors and failure modes? Are upstream dependencies reliable?
Evidence confidence	How trustworthy, current, complete and independently challengeable is the evidence? Record Low / Medium / High separately from effectiveness.

Control credit rule. Planned, proposed or undocumented controls receive no current residual-risk credit. Low evidence confidence does not automatically increase the numerical rating; it blocks confident acceptance and triggers additional review where the conclusion depends on that control.

10. Residual risk

Current residual risk is reassessed after considering only implemented and operating controls. It is not calculated as inherent risk x (1 - control effectiveness). The assessor repeats the impact and likelihood judgment for the scenario in its controlled state.

- Likelihood will often decrease when preventive, detective or human-review controls reduce the chance that the event occurs or propagates.
- Impact should decrease only when controls genuinely limit the consequence, affected scope, duration or reversibility. A preventive control alone does not make the consequence less severe if it fails.
- A new control can introduce dependencies or secondary risks; these should be captured as separate scenarios where material.
- Target residual risk is a future planning state after treatment and must never be presented as current residual risk.
- If the residual conclusion relies on unverified key controls, the risk may be recorded provisionally but must not be accepted for material production use until evidence is sufficient.

11. Risk acceptance criteria

Risk acceptance is a documented governance decision, not the absence of action. Acceptance authority applies only after legal/regulatory stop-gates and mandatory specialist reviews are satisfied.

Residual band	Acceptance criteria	Minimum authority
Low	No material stop condition; controls appropriate to context; owner accepts and monitoring is defined.	Business/System Owner within delegated authority.
Moderate	Controls and monitoring documented; material assumptions visible; no unresolved specialist blocker. Any untreated gap has owner/date.	Business/System Owner + AI Governance/Risk second-line concurrence.
High	Business justification documented; treatment plan, key control evidence, monitoring/KRIs, time-bound review and exit/suspension criteria defined. System owner cannot self-accept.	AI Governance Committee; relevant Legal/Security/Privacy/HR/Product Safety challenge as applicable.
Critical	Not acceptable for normal new production deployment. Must normally be avoided, reduced, suspended or contained. Any exceptional continued-use/acceptance decision must be explicit, time-limited and supported by documented challenge and compensating measures.	Executive Sponsor + CRCO with Board Audit & Risk Committee oversight; AI Governance Committee cannot accept alone.

11.1 Non-acceptance conditions

- A practice determined to be prohibited or otherwise unlawful under applicable law.
- A material AI use case with no accountable owner or no sufficiently defined intended purpose/decision boundary.
- A production decision where required human authority has been removed, bypassed or cannot be demonstrated.
- A risk conclusion that depends on a key control that is only planned, not implemented.
- A critical assumption that invalidates the assessment and has not been resolved or explicitly escalated.

12. Escalation thresholds

Trigger	Required escalation
Critical current residual risk	Immediate AI Governance Committee and executive escalation; block new production deployment pending

Trigger	Required escalation
	decision.
High current residual risk for production/continued material use	AI Governance Committee approval, treatment plan and enhanced evidence.
Residual Impact 5 scenario, regardless of matrix band	Mandatory committee review and relevant specialist challenge.
Potential prohibited/unlawful practice or material legal-classification uncertainty	General Counsel / Legal and Risk review before approval; legal gate overrides internal score.
Material impact on employment, safety, fundamental rights or vulnerable/affected individuals	Relevant domain specialist review (e.g., HR, Privacy, Product Safety) and committee visibility.
Loss of human oversight, serious incident, discriminatory outcome, confidential-data leakage or control failure	Event-driven reassessment and suspension/containment decision as appropriate.
Unregistered production AI or AI-007 discovered material use	Containment/discovery workflow; create separate inventory record before formal assessment and approval.
Material change in purpose, model/provider, data, affected population, integration, autonomy, geography or control design	Reassessment before continued reliance where the change could alter risk or legal status.
Low evidence confidence for a key control supporting acceptance of a High/Critical inherent scenario	Second-line challenge; acceptance deferred until evidence is adequate or risk is explicitly escalated.

13. Where numerical scoring creates false precision

Numerical risk methods are useful for consistency, but AI risk often involves sparse evidence, novel failure modes, non-financial harms and rapidly changing systems. The following uses of numbers would overstate certainty and are prohibited or constrained in this methodology.

False-precision risk	Why it is misleading	Duckworks safeguard
Treating 1-5 scales as interval measurements	The difference between “2” and “3” is not demonstrably equal to the difference between “4” and “5”.	Treat values as ordinal coordinates; preserve anchor text and rationale.
Using Impact x Likelihood as the authoritative risk quantity	A product such as 12 is not a measured loss probability and cannot be interpreted arithmetically.	Matrix band is authoritative; optional product is sorting-only.
Assuming equal products mean equal risks	Impact 5 / Likelihood 2 and Impact 2 / Likelihood 5 can have very different governance implications.	Retain the I/L pair and apply Impact-5 escalation override.
Averaging scenario or domain scores	A severe safety or rights scenario can disappear inside an average of lower risks.	System roll-up uses the highest material scenario, not an average.
Weighted domain scores	Weights create the appearance of a calibrated model without empirical justification and can encode value judgments invisibly.	No portfolio-wide domain weighting unless separately validated and approved.
Control-effectiveness percentages	“70% effective” rarely has an evidential basis and implies linear risk reduction.	Use categorical design/operating/evidence conclusions.
Residual = inherent x (1 - control %)	Controls affect likelihood, consequence, detection and dependencies differently; some introduce new risks.	Reassess impact and likelihood after operating controls.
Precise likelihood percentages for novel AI failure modes	Sparse incidents, rapid model change and unknown exposure make probability estimates unstable.	Use anchored ordinal likelihood plus horizon, evidence and confidence.
Exact ranking of adjacent matrix results	A “12” is not necessarily meaningfully safer than a “15”; assessor uncertainty can exceed the difference.	Prioritize by band, impact severity, legal/safety/rights flags, evidence confidence and treatment urgency.
Single system score as complete truth	Different affected groups, use contexts and scenarios can have materially different risk profiles.	Keep scenario-level records and affected-party analysis; system band is a governance roll-up only.

Assessor rule. When the narrative, evidence or expert judgment conflicts with a calculated number, investigate the disagreement. Do not force the narrative to fit the number.

14. Evidence, assumptions and confidence

Every material rating must be traceable to evidence or a documented assumption. Duckworks' assumptions register treats changes in intended purpose, affected persons, legal role, safety impact, data category and degree of automation as potential reassessment triggers. Control evidence should be current enough to support the claimed operating state.

Record	Minimum content
Scenario rationale	Cause, event, impact, affected parties, scope and key dependencies.
Inherent rating basis	Impact anchor, likelihood anchor, assessment horizon, assumptions and evidence references.
Control assessment	Control owner, design/operation conclusion, evidence references, gaps and confidence.
Residual rating basis	Which aspects of impact/likelihood changed and why; no unsupported arithmetic discounting.
Decision record	Treatment, acceptance authority, conditions, due dates, monitoring and suspension/exit criteria.
Reassessment trigger	Material change, incident, threshold breach, evidence expiry or scheduled review.

15. Methodology approval and implementation sequence

- Risk & Compliance circulates this v0.9 draft for review by the CRCO, AI Governance Lead, CISO, General Counsel, DPO, Head of Data & AI, HR and Product Safety representatives.
- Reviewers confirm the impact/likelihood anchors, risk matrix, control-effectiveness categories, acceptance authorities, escalation rules and false-precision safeguards.
- The CRCO / AI Governance Committee formally approves the methodology and assigns an effective version.
- Only after approval are the Inherent Risk, Control Effectiveness and Residual Risk fields in the approved inventory populated.
- System assessments are performed scenario by scenario, with AI-007 decomposed into distinct material use cases as they are discovered.
- Results are quality-checked for cross-artifact consistency before management reporting or portfolio publication.

Status at issuance. Methodology design complete for review. System scoring is intentionally deferred. Existing artifacts that contain risk-assessed values should not be treated as the authoritative baseline for this approval cycle until the methodology is approved and assessments are re-performed or formally reconciled.

Appendix A - Minimum scenario assessment record

Field	Required entry
AI ID / system	Use approved inventory identifier.
Scenario ID	Stable unique scenario identifier.
Cause -> Event -> Impact	Specific, auditable risk statement.
Affected parties / assets	Individuals, groups, operations, products, data or suppliers affected.
Assessment horizon	Period or lifecycle window used for likelihood judgment.
Inherent impact	1-5 + anchor rationale.
Inherent likelihood	1-5 + evidence rationale.
Inherent band	Matrix result; no system values until methodology approval.
Key implemented controls	Controls that are actually operating.
Control effectiveness	Categorical rating + design/operation rationale.
Evidence confidence	Low / Medium / High + evidence references.
Residual impact	1-5 + explanation of any change.
Residual likelihood	1-5 + explanation of any change.
Residual band	Matrix result.

Field	Required entry
Treatment	Avoid / reduce / transfer-share / accept / suspend / retire.
Target residual	Future planning state only.
Approval authority	Per Section 11.
Monitoring / KRI	Metric, threshold, cadence, owner.
Reassessment trigger	Change, incident, control failure, evidence expiry or scheduled review.

Appendix B - Project source basis

- Duckworks AI System Inventory (approved baseline) - authoritative scope and “Not Assessed until methodology approval” rule.
- Duckworks AI Governance Project - Business Scenario - governance mandate and proportionality principle.
- Duckworks Project Assumptions Register v1.0 - assumption materiality, control-credit rule and critical risk appetite assumption.
- Duckworks Project Stakeholder Register v1.0 - roles, committee structure, specialist challenge and escalation triggers.
- Duckworks Project Acceptance Criteria v1.0 - requirement for severity, likelihood, thresholds, residual risk, control credit, treatment and escalation.
- Duckworks Public Frameworks, Legislation & Guidance - source hierarchy and separation of binding law from voluntary guidance.
- NIST AI RMF, ISO/IEC 42001, ISO/IEC 23894 and ISO/IEC 42005 are design references only; this document does not reproduce their clauses or claim conformity.

Portfolio disclaimer. Duckworks, Project W.I.N.G., all named individuals, systems, data, decisions and evidence in this document are fictional and created solely for educational and professional portfolio purposes. This methodology is not legal advice, certification evidence or a compliance determination.